Studio Nx

JS 03 — safeNextPath()

2026-10-06

JS 03 — `safeNextPath(next, origin)`

항목	내용
파일	`studionx/frontend/static/js/core/auth.js`
작업	P1-02 프론트 공통 JS · PRD 01 FR-105
작성	Claude (AI) · 2026-10-06 · 사용자 검토
이전 · 다음	02 `apiFetch()` · 04 `loginUrl()`

1. 하는 일

로그인 후 돌아갈 주소(`next`)가 **우리 사이트 안의 경로**인지 검사한다. 안전하면 그대로, 아니면 `null`.

2. 언제 쓰나

로그인이 필요한 페이지(마이페이지 · 내 프로젝트 · 회원 정보 · 시퀀서)에 로그인 없이 들어오면 `home.html#login?next=/myPage.html` 로 보낸다. 로그인 모달에서 로그인에 성공하면 `next` 로 돌아간다.

상황	부르는 곳
주소의 `#login?next=…` 를 읽을 때	`parseLoginHash()` (05) → `home.js` 로그인 모달
로그인 성공 후 이동하기 직전	로그인 폼 처리 (P1-07) — 한 번 더 확인

막는 공격 — 열린 리다이렉트 (open redirect)

`next` 는 주소창에 그대로 들어 있어 **누구나 바꿀 수 있다**. 검사가 없으면:

1. 공격자가 `https://studionx…/home.html#login?next=https://evil.com/fake-login` 링크를 보낸다.
2. 사용자는 진짜 Studio Nx 주소라 믿고 로그인한다.
3. 로그인 직후 가짜 사이트로 이동 → "비밀번호를 다시 입력하세요" 같은 피싱.

그래서 **같은 사이트 경로만** 허용한다.

3. 코드

```
export function safeNextPath(next, origin = location.origin) {
  if (typeof next !== 'string' || !next.startsWith('/')) return null;
  if (next.startsWith('//') || next.includes('\\')) return null;
  try {
    return new URL(next, origin).origin === origin ? next : null;
  } catch {
    return null;
  }
}
```

문법 풀이

식	뜻
`origin = location.origin`	기본값 매개변수 — 보통은 지금 사이트(`http://localhost:8000`). 시험 때만 다른 값을 넣음
`typeof next !== 'string'`	문자열이 아니면(`null` · `undefined` · 숫자) 거부
`'\\'`	자바스크립트 문자열 안의 역슬래시 한 글자 `\`
`new URL(next, origin)`	`next` 를 `origin` 기준으로 해석한 완전한 주소. `new URL('/a', 'http://x')` → `http://x/a`
`.origin === origin`	해석한 주소의 `프로토콜://호스트:포트` 가 우리 사이트와 같은지
`try … catch`	이상한 문자열로 `new URL` 이 오류를 내면 `null`

4. 흐름

1. 문자열이 아니거나 `/` 로 시작하지 않으면 거부 — `https://…`, `javascript:…`, `myPage.html` 이 여기서 걸림.
2. `//` 로 시작하거나 `\` 가 있으면 거부 — 브라우저는 이걸 **다른 사이트 주소**로 읽음.
3. 마지막으로 브라우저와 같은 방식(`new URL`)으로 해석해 우리 사이트인지 확인.

5. 왜 이렇게

선택	이유
`/` 로 시작하는 경로만	가장 단순하고 확실한 기준. 전체 주소(`http://…`)는 우리 사이트여도 거부 — 화면은 경로만 넘김
`//evil.com` 거부	"프로토콜 상대 주소" — 브라우저는 `https://evil.com` 으로 이동
`\` 가 들어가면 거부	브라우저는 `/\evil.com` 의 `\` 를 `/` 로 바꿔 `//evil.com` 으로 읽음
`new URL` 로 한 번 더	위 규칙이 놓친 특이한 형태도 실제 해석 결과로 막음
오류 대신 `null`	부르는 쪽은 `null` 이면 기본 페이지로 보내면 됨

6. 시험

입력	결과
`/myPage.html` · `/studioNx.html?projectId=3` · `/myProject.html#new`	그대로
`//evil.com` · `/\evil.com`	`null`
`https://evil.com/x` · `http://localhost:8000/myPage.html`	`null` (전체 주소는 모두 거부)
`javascript:alert(1)` · `myPage.html` · `''`	`null`
`null` · `undefined` · `42`	`null`
`/%2F%2Fevil.com`	그대로 — 해석하면 `http://localhost:8000/%2F%2Fevil.com`(우리 사이트 안의 경로)이라 안전